Practical 12

Event Management CRUD with Poster Upload and File Validation

1. Problem Definition

Develop event management functionality for admin users. The admin can add, view, update and delete events, and can upload an event poster. Every uploaded poster must be validated on the server for file type and file size before it is saved.

2. Objective

- To implement a PHP–MySQL CRUD module for managing events.
- To upload an event poster and validate its type (JPG/PNG only) and size (below 2 MB) on the server side.
- To store only the new random file name of the poster in the database and keep the image file in an uploads folder.
- To display clear success and failure messages to the admin.
- To prevent SQL injection and cross-site scripting using prepared statements and output escaping.

3. Theory

CRUD operations. CRUD stands for Create, Read, Update and Delete, the four basic operations on stored data. In this practical they are done on the events table with the SQL statements INSERT, SELECT, UPDATE and DELETE.

Prepared statements. mysqli_prepare() and mysqli_stmt_bind_param() send the query and the data separately, so user input can never change the structure of the query. This protects the database against SQL injection.

File upload handling. The form uses method="post" and enctype="multipart/form-data". PHP receives the file in the $_FILES array with the keys name, tmp_name, size, type and error. The file is first stored in a temporary location and must be moved with move_uploaded_file().

Server-side file validation. Client-side checks such as the accept attribute can be bypassed, so the server repeats all checks:

- Upload error code is checked ($_FILES["poster"]["error"] against UPLOAD_ERR_OK).
- File size is checked to be at most 2 MB (2 * 1024 * 1024 bytes).
- The real MIME type is read from the file content using finfo (FILEINFO_MIME_TYPE) and compared with a whitelist (image/jpeg, image/png), instead of trusting the type sent by the browser.
- getimagesize() confirms that the file is a genuine image.

- The file is renamed using bin2hex(random_bytes(16)) with a safe extension, so the original file name is never used. This avoids name clashes and script-upload attacks.

Poster replacement. When an event is updated with a new poster, the old poster is deleted from the folder with unlink() only after the database update succeeds. A hidden field old_poster keeps the existing poster when no new file is chosen.

Output escaping. The helper function h() uses htmlspecialchars() with ENT_QUOTES and UTF-8 for every value printed on the page, which prevents XSS.

4. Database Structure

The module uses the table events. Its columns, as used by the code, are:

- **id** (INT, primary key, auto increment) – unique id of the event.
- **title** (VARCHAR 255) – event title, required.
- **event_date** (DATE) – date of the event, required.
- **description** (TEXT) – details of the event.
- **poster** (VARCHAR 255) – stored (renamed) poster file name.

5. Program Flow

1. The admin opens the page; all events are read from the database (SELECT ... ORDER BY id DESC) and shown in a table.
2. To add an event, the admin fills the form and optionally selects a poster, then clicks Add Event.
3. The server checks that title and date are not empty, then validates the poster (error code, size, MIME type, real image).
4. If any check fails, a failure message is shown and nothing is saved. Otherwise the poster is renamed and moved to the uploads folder.
5. When the id is greater than 0 an UPDATE query runs, otherwise an INSERT query runs, both with prepared statements.
6. After a successful update, the old poster file is removed and the page redirects to index.php.
7. Edit loads the event into the form (?edit=id). Delete asks for confirmation (?delete=id) and removes the event.

6. Code

The code of index.php is given below as screenshots .

p12.php

```php
if (isset($_POST['save'])) {
    if ($title == "" || $date == "") {
    } else {

        if (isset($_FILES['poster']) &&
            $_FILES['poster']['error'] != UPLOAD_ERR_NO_FILE) {

            $file = $_FILES['poster'];

            if ($file['error'] != UPLOAD_ERR_OK) {
                $msg = "File upload failed.";
            } elseif ($file['size'] > 2 * 1024 * 1024) {
                $msg = "Poster must be below 2 MB.";
            } else {
                $allowed = [
                    'image/jpeg' => 'jpg',
                    'image/png' => 'png'
                ];

                $mime = (new finfo(FILEINFO_MIME_TYPE))
                    ->file($file['tmp_name']);

                if (!isset($allowed[$mime]) ||
                    @getimagesize($file['tmp_name']) === false) {
                    $msg = "Only valid JPG and PNG images are allowed.";
                } else {
                    $newName = bin2hex(random_bytes(16))
                        . "." . $allowed[$mime];

                    if (move_uploaded_file(
                        $file['tmp_name'],
                        $folder . $newName
                    )) {
                        $poster = $newName;
                    } else {
                        $msg = "Could not save poster.";
                    }
                }
            }
        }

        if ($msg == "") {
            if ($id > 0) {
                $stmt = mysqli_prepare(
                    $conn,
                    "UPDATE events SET title=?, event_date=?,
                     description=?, poster=? WHERE id=?"
                );

                mysqli_stmt_bind_param(
                    $stmt, "ssssi",
                    $title, $date, $description, $poster, $id
                );
            } else {
```

```php
                $stmt = mysqli_prepare(
                    VALUES (?, ?, ?, ?)"
                );

                mysqli_stmt_bind_param(
                    $stmt, "ssss",
                    $title, $date, $description, $poster
                );
            }

            if (mysqli_stmt_execute($stmt)) {
                // Remove old poster after a successful update
                if ($id > 0 && $poster != ($_POST['old_poster'] ?? "")) {
                    $old = $_POST['old_poster'] ?? "";

                    if ($old && is_file($folder . $old)) {
                        unlink($folder . $old);
                    }
                }

                header("Location: index.php");
                exit;
            } else {
                $msg = "Database operation failed.";
            }
        }
    }
}

// DISPLAY EVENTS
$result = mysqli_query($conn, "SELECT * FROM events ORDER BY id DESC");

Windsurf: Refactor | Explain | Generate Function Comment | ×
function h($value) {
    return htmlspecialchars((string)$value, ENT_QUOTES, 'UTF-8');
}
?>

<!DOCTYPE html>
<html>
<head>
    <title>Event Management</title>
    <style>
        body {
            font-family: Arial;
            margin: 30px;
        }

        input, textarea, button {
            padding: 8px;
```

```php
<h2>Event Management System</h2>

<p><?php echo h($msg); ?></p>

<h3><?php echo $edit ? "Update Event" : "Add Event"; ?></h3>

<form method="post" enctype="multipart/form-data">
    <input type="hidden" name="id"
           value="<?php echo h($edit['id'] ?? ''); ?>">

    <input type="hidden" name="old_poster"
           value="<?php echo h($edit['poster'] ?? ''); ?>">

    <label>Event Title</label>
    <input type="text" name="title" required
           value="<?php echo h($edit['title'] ?? ''); ?>">

    <label>Event Date</label>
    <input type="date" name="event_date" required
           value="<?php echo h($edit['event_date'] ?? ''); ?>">

    <label>Description</label>
    <textarea name="description"><?php
        echo h($edit['description'] ?? '');
    ?></textarea>

    <label>Poster (JPG/PNG, maximum 2 MB)</label>
    <input type="file" name="poster" accept=".jpg,.jpeg,.png,image/jpeg,image/png">

    <?php if (!empty($edit['poster'])): ?>
        <p>Current poster:</p>
        <img src="<?php echo h($folder . $edit['poster']); ?>"
             alt="Current poster">
    <?php endif; ?>

    <br>
    <button type="submit" name="save">
        <?php echo $edit ? "Update Event" : "Add Event"; ?>
    </button>

    <?php if ($edit): ?>
        <a href="index.php">Cancel</a>
    <?php endif; ?>
</form>

<hr>

<h3>All Events</h3>

<table>
    <tr>
        <th>ID</th>
        <th>Title</th>
        <th>Date</th>
```

```php
    </tr>

    <?php while ($row = mysqli_fetch_assoc($result)): ?>
    <tr>
        <td><?php echo h($row['id']); ?></td>
        <td><?php echo h($row['title']); ?></td>
        <td><?php echo h($row['event_date']); ?></td>
        <td><?php echo h($row['description']); ?></td>

        <td>
            <?php if ($row['poster']): ?>
                <img src="<?php echo h($folder . $row['poster']); ?>"
                     alt="Event poster">
            <?php else: ?>
                No poster
            <?php endif; ?>
        </td>

        <td>
            <a href="index.php?edit=<?php echo h($row['id']); ?>">
                Edit
            </a>

            <a href="index.php?delete=<?php echo h($row['id']); ?>"
               onclick="return confirm('Delete this event?')">
                Delete
            </a>
        </td>
    </tr>
    <?php endwhile; ?>
</table>

</body>
```

7. Output

The output of the program for each operation is shown below.

1. Add Event form

Empty form with Event Title, Event Date, Description and Poster fields.

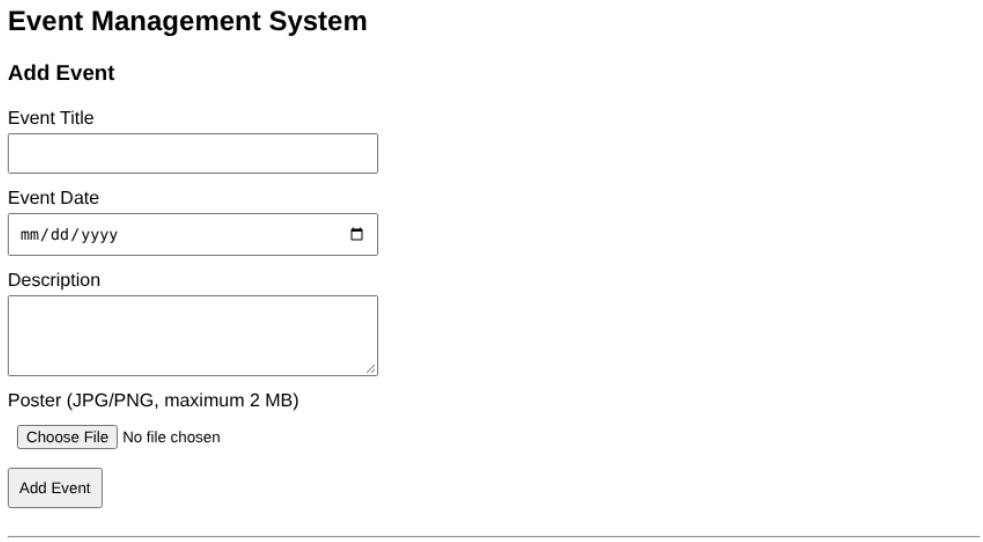


Figure: Add Event form

2. Event added successfully

Event list after adding a new event with a valid JPG/PNG poster.

Event Management System

Add Event

Event Title

Event Date

mm/dd/yyyy

Description

Poster (JPG/PNG, maximum 2 MB)

Choose File No file chosen

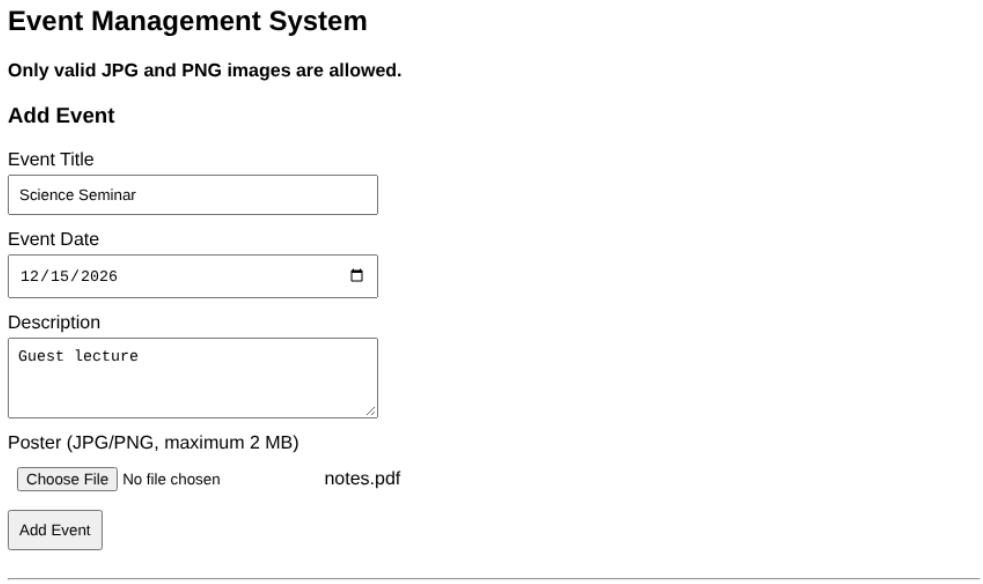
Add Event

All Events

ID	Title	Date	Description	Poster	Action
3	Hackathon	2026-12-05	24-hour coding contest		Edit | Delete
2	Cultural Night	2026-11-20	Music and dance performances		Edit | Delete
1	Tech Fest	2026-11-10	Annual technical festival		Edit | Delete

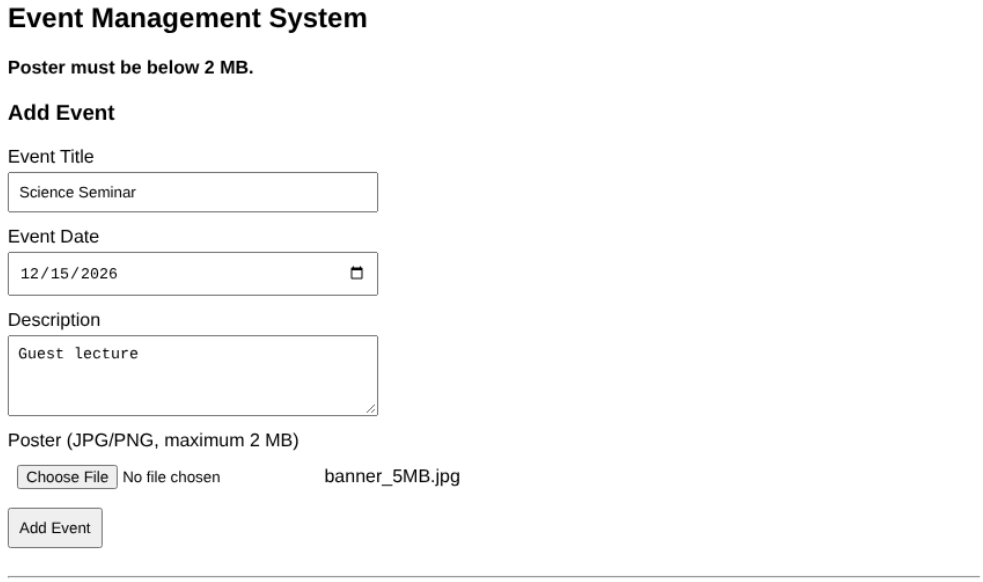
3. Invalid file type rejected

A file such as PDF or TXT is chosen; the message "Only valid JPG and PNG images are allowed." appears.



4. File size above 2 MB rejected

An image larger than 2 MB is chosen; the message "Poster must be below 2 MB." appears.



5. Update event

Edit form showing the current poster, and the list after the update.

Event Management System

Update Event

Event Title

Cultural Night

Event Date

11/20/2026

Description

Music, dance and drama performances

Poster (JPG/PNG, maximum 2 MB)

Choose File No file chosen

Current poster:



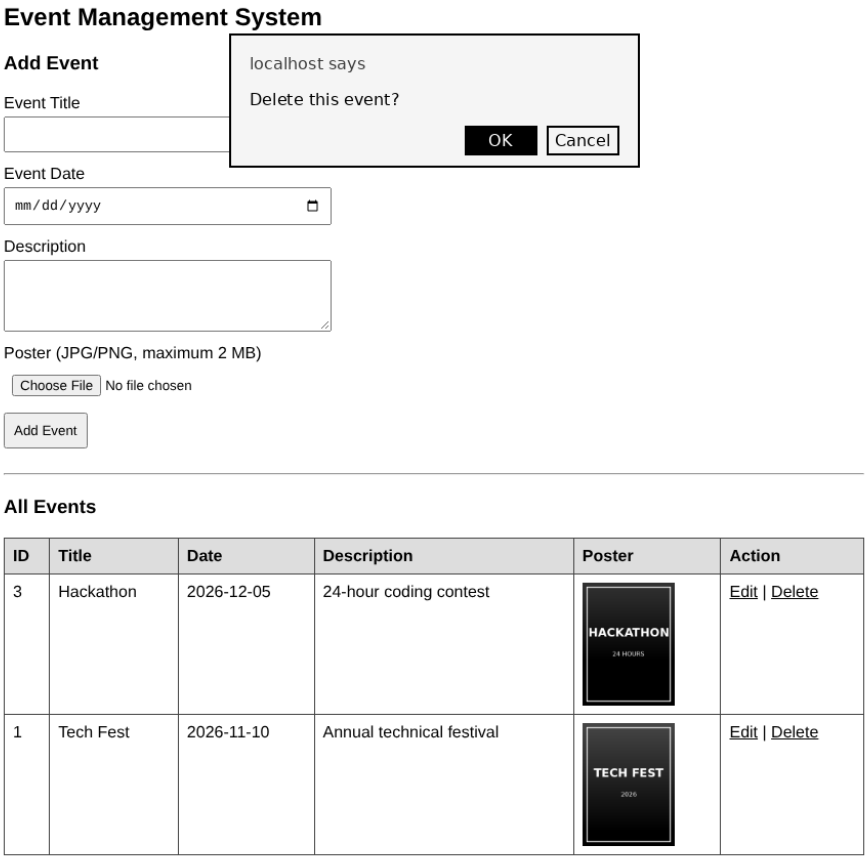
Update Event Cancel

All Events

ID	Title	Date	Description	Poster	Action
3	Hackathon	2026-12-05	24-hour coding contest		Edit | Delete
2	Cultural Night	2026-11-20	Music and dance performances		Edit | Delete
1	Tech Fest	2026-11-10	Annual technical festival		Edit | Delete

6. Delete event

Browser confirmation "Delete this event?" and the list after deletion.



8. Learning Outcome

After completing this practical, I learned to build a secure CRUD module in PHP and MySQL with validated file upload. I understood why server-side validation is needed, how to check the real file type and size, how to rename uploaded files safely, and how prepared statements and output escaping protect the application from SQL injection and XSS.

9. References

- PHP Manual – Handling file uploads: https://www.php.net/manual/en/features.file-upload.php
- PHP Manual – MySQLi prepared statements: https://www.php.net/manual/en/mysqli.quickstart.prepared-statements.php
- PHP Manual – finfo class: https://www.php.net/manual/en/class.finfo.php